Cyber-Bedrohungen & Resilienzstrategien

Vorlesungsskript · Sitzung 4 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

1. Einleitung und Zielsetzung der Sitzung

Die bisherigen Sitzungen behandelten Resilienz zunächst aus einer definitorischen und messorientierten Perspektive (Sitzung 1 und 2) und anschließend aus architekturtechnischer Sicht (Sitzung 3). In dieser vierten Sitzung wird derselbe Gegenstand — Resilienz — nun **bedrohungsgetrieben** betrachtet: Resilienz wird nicht abstrakt verstanden, sondern stets in Bezug auf konkrete Störereignisse und Angriffsszenarien.

Resilienz ist im Kern nie allgemeingültig, sondern **immer relational**: Ein System ist nur insofern resilient, als es gegen *etwas Konkretes* widerstands- oder wiederherstellungsfähig ist. In diesem Sinne ist Resilienz nicht nur ein Architekturprinzip, sondern auch eine **Antwort auf Bedrohungsklassen**. Diese Perspektive findet sich u. a. explizit in NIST SP 800-160 Vol. 2 (*Cyber Resilience Engineering*), das Resilienzfähigkeiten funktional an Bedrohungsszenarien koppelt, sowie in den sektoralen Leitlinien von ENISA und dem BCM-Ansatz des BSI-Standards 200-4.

Die Sitzung verfolgt drei Ziele:

1. **Bedrohungen als Resilienztreiber identifizieren**
   - Ransomware, DDoS, Cloud-Ausfälle, Identity-Ausfälle, Human Failure, Supply-Chain-Angriffe
2. **Zuordnung von Bedrohungen zu Resilienzprinzipien**
   - Mapping von Threats auf Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität
3. **Ableitung konkreter technischer Resilienzmaßnahmen**
   - nicht im Sinne von Prävention, sondern zur Aufrechterhaltung bzw. Wiederherstellung der Funktionsfähigkeit

Die Sitzung etabliert damit den notwendigen Brückenschlag zwischen *Threat Intelligence* und *Resilience Engineering*. Sie beantwortet nicht die Frage, wie man Angriffe verhindert, sondern wie Systeme so gestaltet werden, dass sie **trotz realer Ereignisse weiter funktionsfähig bleiben oder kontrolliert zurückkehren können**.

2. Bedrohungsklassen als Auslöser für Resilienzanforderungen

Resilienzmaßnahmen entstehen nicht im Vakuum, sondern werden durch konkrete Bedrohungsszenarien begründet. In der Praxis zeigt sich, dass wenige wiederkehrende Bedrohungsklassen den überwiegenden Anteil realer Resilienzanforderungen determinieren. Diese Bedrohungen unterscheiden sich weniger in ihrer technischen Ursache als in ihrem **Wirkmechanismus auf die Funktionsfähigkeit** eines Systems.

2.1 Ransomware und destruktive Malware

Diese Klasse von Bedrohungen zielt nicht primär auf Datenexfiltration, sondern auf **Denial-of-Service durch Sabotage** (Verschlüsselung, Löschung, Korrumpierung). Relevanz für Resilienz: Recovery-Fähigkeit tritt als *primäre Verteidigungslinie* auf.

2.2 DDoS- und Lastangriffe

Diese Angriffe zerstören keine Ressourcen, sondern **verbrauchen sie schneller als sie bereitgestellt werden können**. Sie testen nicht Integrität, sondern Kapazität und Adaptivität.

Relevanz für Resilienz: Systeme müssen unter Degradation weiter liefern können.

2.3 Infrastruktur- und Cloud-Provider-Störungen

Regionale Cloud-Ausfälle, Stromausfälle, Netzwerk-Partitionen oder physische RZ-Störungen führen zu **extern erzwungenen Betriebsunterbrechungen**. Relevanz für Resilienz: Redundanz und Fallback-Konzepte entscheiden über Weiterbetrieb.

2.4 Identity- und Authentifizierungs-Ausfälle

Systeme können intakt sein und dennoch unbenutzbar werden, wenn zentrale Identity-Provider (AD/IdP) ausfallen oder kompromittiert werden. Relevanz für Resilienz: Identity fungiert als häufig unterschätzter Single Point of Failure.

2.5 Human Failure und Fehlkonfiguration

Ein signifikanter Anteil realer Großausfälle ist nicht Angriff, sondern **Fehlerfortpflanzung über Automatisierung** (IaC, CI/CD, Fehldeployments). Relevanz für Resilienz: Wiederherstellbarkeit und Rollbackfähigkeit überkompensieren menschliche Fehlbarkeit.

2.6 Supply-Chain-Angriffe

Kompromittierung über Drittanbieter bzw. Abhängigkeiten führt zu *importierter Fragilität* (SolarWinds, Kaseya).

Relevanz für Resilienz: Diversität und vertrauensunabhängige Recovery-Pfade sind Schlüsselfaktoren.

Zwischenfazit: Diese Bedrohungsklassen unterscheiden sich in ihrer Ursache, aber sie **konvergieren in ihren Effekten**: Verlust von Verfügbarkeit, Nutzbarkeit, Steuerbarkeit oder Integrität. Genau diese Effekte bestimmen, **welches Resilienzprinzip** angewendet werden muss.

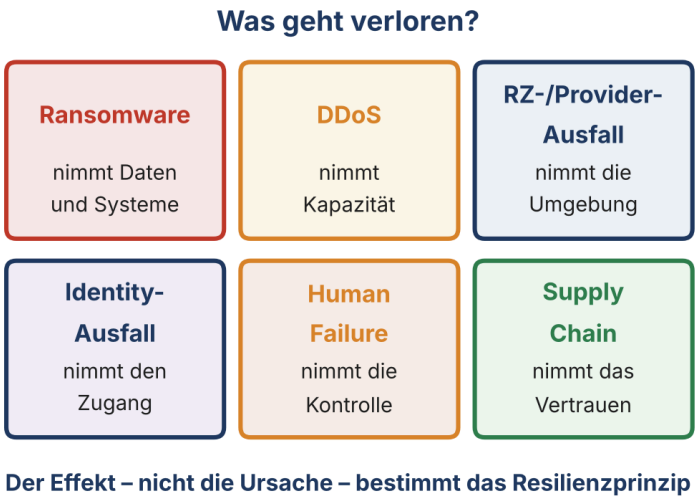


Abbildung 1: Sechs Bedrohungsklassen und was sie dem System nehmen

3. Mapping: Von Bedrohung zu Resilienzprinzip (Threat → Capability)

Resilienzmaßnahmen entfalten nur dann Wirkung, wenn sie an den **Wirkmechanismus** einer Bedrohung anschließen. Die Bedrohung definiert also nicht nur *dass* Resilienz benötigt wird, sondern *welche Art* von Resilienzfähigkeit erforderlich ist.

Das folgende Mapping bildet diese Beziehung zwischen Ursache (Threat), Wirkung (systemischer Effekt) und Gegenprinzip (Resilience Capability) ab.

Bedrohung	Wirkung auf das System	Relevantes Resilienzprinzip
Ransomware	vollständiger Funktionsverlust	**Wiederherstellbarkeit (Recovery)**
DDoS / Lastangriffe	Degradation statt Zerstörung	**Adaptivität**
Cloud-/RZ-Ausfall	infrastrukturelle Nichtverfügbarkeit	**Redundanz**
Identity-Ausfall	Nutzungsunfähigkeit trotz intakter Systeme	**Diversität & Recovery**
Human Failure	ungewollte Fehlpropagation	**Rollback / Wiederherstellbarkeit**
Supply-Chain-Angriff	externer Fehler importiert	**Diversität & Isolation**

Die Mapping-Logik zeigt:

- Die Bedrohung entscheidet **nicht über das Tool**, sondern über das **Prinzip**, das anzuwenden ist.
- Verschiedene Bedrohungen können dasselbe Prinzip adressieren (z. B. Ransomware & Human Failure → Recovery).
- Dasselbe Prinzip kann gegen sehr verschiedene Bedrohungen wirken (z. B. Diversität gegen Identity-Ausfall & Supply-Chain).

Dieses Denken entspricht dem von NIST SP 800-160 Vol. 2 beschriebenen Paradigma „Capability-based Resilience“:

Nicht die Bedrohung wird kontrolliert — sondern die Fähigkeit, ihren Effekt zu absorbieren.

4. Ausgewählte Bedrohungen im Detail & zugehörige Resilienzstrategien

Die im Mapping skizzierten Zusammenhänge werden im Folgenden exemplarisch vertieft. Ziel ist nicht die vollständige technische Abdeckung, sondern das Verständnis des Wirkmechanismus und der **resilienzrelevanten Gegenmaßnahmen** im Gegensatz zu reiner Prävention.

4.1 Ransomware / destruktive Angriffe

Wirkmechanismus: Funktionsverlust durch Verschlüsselung oder Löschung produktiver Systeme (inkl. Replikate/Backups bei lateralem Spread).

Resilienzstrategien:

- Immutable / offline Backups (nicht durch denselben Blast-Radius beeinflussbar)
- Gold-Images & Clean-Room-Recovery
- Geübte Recovery-Tests (nicht nur Planexistenz)

Prinzipbezug: Wiederherstellbarkeit > Prävention (vgl. ISO/IEC 27031; BSI-200-4: testing over documentation)

Ergänzung zur Vorlesung: Hochschule Mainz 2025

Am 24. November 2025 fuhr die Hochschule Mainz nach einem Cyberangriff ihre IT-Systeme herunter. E-Mail war nur eingeschränkt nutzbar, die Ermittlungsbehörden wurden eingebunden, und ein Krisenstab sollte Studierende und Beschäftigte arbeitsfähig halten. Die Präsenzlehre lief weiter; informiert wurde über die Campus2Go-App, Instagram und LinkedIn.

Der Wiederaufbau folgte dem Muster der Clean-Room-Recovery: Alle Betroffenen erhielten neue Zugangsdaten, alle IT-verwalteten Geräte wurden eingesammelt und mit neuen System-Images ausgerollt – systemrelevante Bereiche zuerst. Die Zahlungsfähigkeit war vor Weihnachten wiederhergestellt, eduroam im Februar 2026 wieder an allen Standorten verfügbar. Viele Abläufe liefen über Monate mit höherem organisatorischem Aufwand.

Der Fall zeigt zweierlei: Nach einem destruktiven Angriff heißt Recovery Neuaufbau statt Reparatur, und Resilienz misst sich zuerst an den Kernfunktionen, nicht an der vollständigen Normalität. Dargestellt sind ausschließlich die veröffentlichten Angaben der Hochschule.

Quellenangaben unter Quellen.

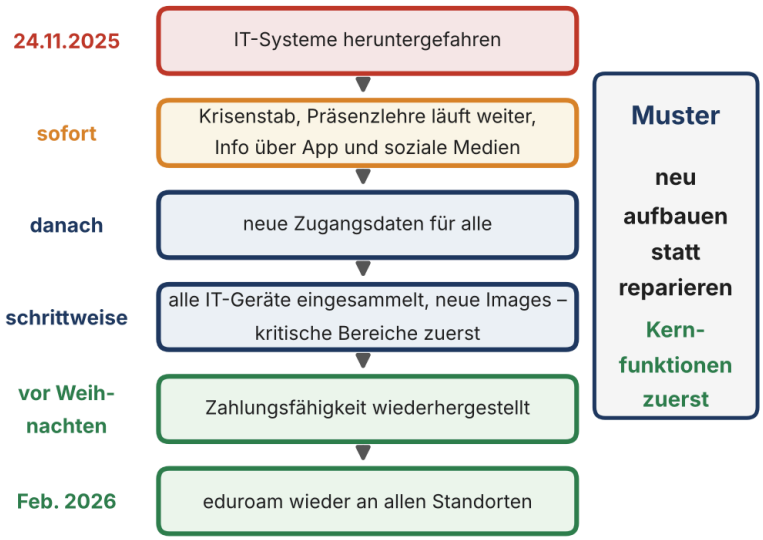


Abbildung 2: Wiederaufbau an der Hochschule Mainz (veröffentlichte Angaben)

4.2 DDoS / Lastangriffe

Wirkmechanismus: Nicht Zerstörung, sondern **kapazitive Erstickung** — Dienst technisch intakt, aber nicht konsumierbar.

Resilienzstrategien:

- Anycast-CDN / Scrubbing / Rate-Limiting
- Auto-Scaling statt statischer Kapazität
- Graceful Degradation (z. B. reduzierte API-Funktionalität)

Prinzipbezug: Adaptivität als Resilienzform (vgl. ENISA DDoS Best Practices)

> Ergänzung zur Vorlesung: Dyn und das Mirai-Botnetz 2016
>
> Am 21. Oktober 2016 trafen zwei Angriffswellen den DNS-Anbieter Dyn, vor allem dessen Standorte an der US-Ostküste. Hauptquelle des Angriffsverkehrs war nach Dyns Analyse das Mirai-Botnetz aus gekaperten IoT-Geräten wie Kameras und Routern; Dyn schätzte bis zu 100.000 beteiligte Endpunkte. Ein Sturm legitimer Wiederholungsanfragen ließ den Angriff zusätzlich größer erscheinen. Dienste wie Twitter, Spotify und Reddit waren für viele Nutzer zeitweise nicht erreichbar.
>
> Die Webserver dieser Dienste waren intakt – nur ihre Namen ließen sich nicht mehr auflösen. Der Fall verbindet zwei Prinzipien: Adaptivität beim Anbieter (Scrubbing, Lastverteilung) und Diversität beim Kunden (ein zweiter, unabhängiger DNS-Anbieter).
>
> Quellenangaben unter Quellen.

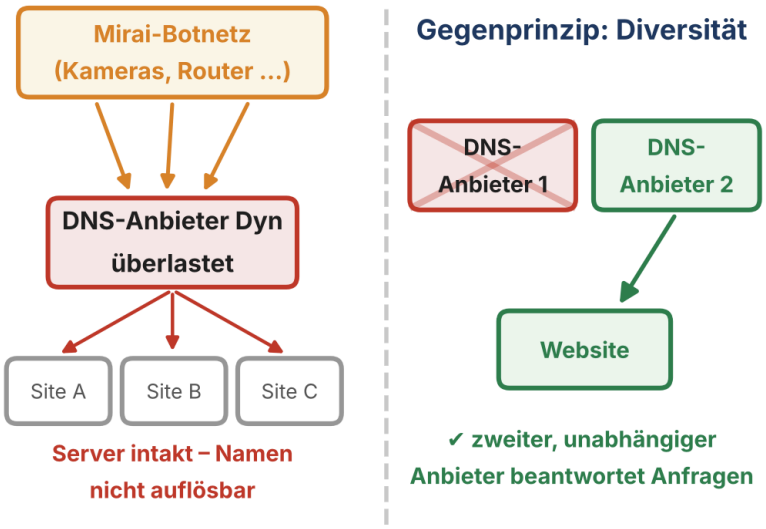


Abbildung 3: Dyn 2016: ein DNS-Anbieter als gemeinsamer Fehlerpfad

4.3 Cloud-/RZ-Ausfall

Wirkmechanismus: Umgebung fällt exogen aus, Funktion bricht nicht wegen des Systems, sondern wegen des Standortes/Providers.

Resilienzstrategien:

- Multi-AZ / Multi-Region / Multi-Cloud
- Lokale Fallback-Services für Minimalbetrieb
- Trennung von Steuer- und Ausführungsdomäne

Prinzipbezug: Redundanz + Entkopplung (vgl. NIST SP 800-160 Vol.2 „Diversity of Location“)

> Ergänzung zur Vorlesung: KDZ Mainz und KGRZ Koblenz 2026
>
> Am 27. September 2026 schalteten die kommunalen Rechenzentren KDZ Mainz und KGRZ Koblenz, die Betriebszentren des Zweckverbands ZIDKOR, zentrale Fachverfahren vorsorglich ab. Anlass waren kritische Sicherheitslücken in Citrix NetScaler. Betroffen waren alle 194 hauptamtlich geführten Städte, Gemeinden und Kreise in Rheinland-Pfalz: Einwohnermeldeämter, Pass- und Ausweisstellen, Kfz-Zulassung, Standesämter, Waffenbehörden und Schulverwaltungsprogramme. Das Land schaltete zusätzlich über Citrix erreichbare Dienste des Landesnetzes ab. Am 29. September waren die Verfahren nach Updates und Prüfung wieder verfügbar; nach Angaben der Betreiber gab es keinen erfolgreichen Angriff.
>
> Der Fall zeigt das **Konzentrationsrisiko** gemeinsamer Dienstleister: Zentralisierung macht einen professionellen Betrieb für kleine Verwaltungen erst möglich – und bündelt zugleich das Ausfallrisiko.
>
> Quellenangaben unter Quellen.



Abbildung 4: KDZ/KGRZ 2026: ein gemeinsamer Dienstleister, 194 Verwaltungen

Ergänzung zur Vorlesung: Vorsorgliches Abschalten als Resilienzentscheidung

Eine bekannte, kritische Lücke stellt Betreiber vor eine Abwägung. Läuft der Dienst weiter, bleibt er verfügbar, trägt aber ein offenes Risiko – im schlimmsten Fall Einbruch, Datenabfluss und ein Wiederaufbau über Wochen. Wird er vorsorglich abgeschaltet, entsteht ein geplanter Ausfall mit absehbarer Dauer. Bezogen auf die Resilienzkurve aus Sitzung 2 wird bewusst ein kleiner, kurzer Einbruch in Kauf genommen, um einen tiefen und langen zu vermeiden.

Voraussetzung sind ein vorbereiteter Notbetrieb und klare Entscheidungsrechte. Ein Beispiel für abgestufte Wirkung: Am 21. Oktober 2026 nahm die Stadt Mainz wegen einer kritischen PHP-Lücke ihre Website und weitere Internetdienste vom Netz, während Ämter, Telefon und E-Mail weiterliefen.

Quellenangaben unter Quellen.



Abbildung 5: Weiterlaufen oder vorsorglich abschalten

4.4 Identity-Ausfall

Wirkmechanismus: Systeme intakt, aber **nicht benutzbar**, da Authentisierung/Token-Ausgabe zentral blockiert.

Resilienzstrategien:

- Break-Glass-Accounts außerhalb des Identity-Stacks
- Zweiter unabhängiger IdP / Offline-Auth-Pfad
- Minimal-Access-Mechanismen ohne Cloud-Abhängigkeit

Prinzipbezug: Diversität + Recovery (vgl. Zero Trust Architecture — Reduktion globaler Kopplungspunkte)

> Ergänzung zur Vorlesung: Azure AD 2021
>
> Am 15. März 2021 entfernte ein automatischer Prozess bei Microsoft einen Signierschlüssel, der wegen einer Migration als „behalten“ markiert war; ein Fehler in der Automatik ignorierte diese Markierung. Ab etwa 19:00 UTC verwarfen Anwendungen die mit diesem Schlüssel signierten Tokens, Anmeldungen scheiterten. Betroffen waren unter anderem Teams, Exchange, SharePoint, das Azure-Portal, Xbox Live sowie Anwendungen Dritter, die Azure AD zur Anmeldung nutzen. Der Rollback erfolgte um 21:05 UTC, Restwirkungen hielten bis zum nächsten Morgen an.
>
> Bemerkenswert: Die vorhandene Backup-Authentisierung half nicht, weil sie die Ausgabe von Tokens abdeckte, nicht ihre Prüfung. Eine Rückfallebene muss genau den Fehlerfall abdecken, der eintritt. Der Fall zeigt Identity als globalen Fail-Knopf – die Systeme liefen, nur der Zugang nicht.
>
> Quellenangaben unter Quellen.

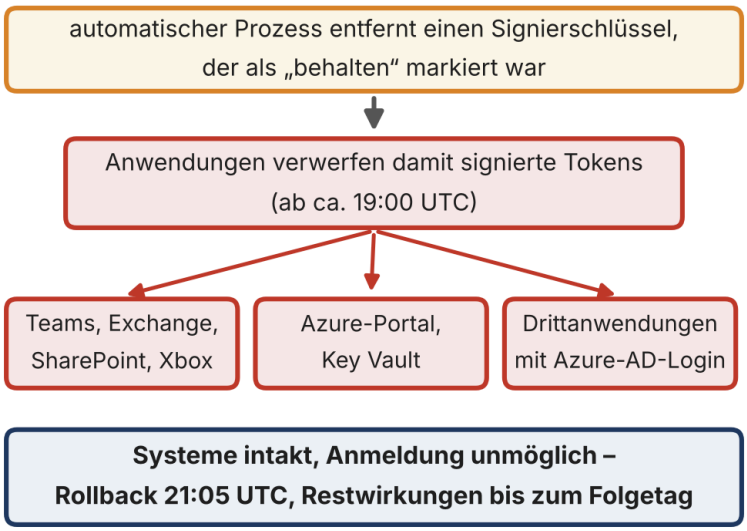


Abbildung 6: Azure AD 2021: Systeme intakt, Anmeldung unmöglich

4.5 Human Failure / Fehlkonfiguration

Wirkmechanismus: Fehler multipliziert sich über Automatisierung (CI/CD/IaC), aus lokalem Fehler wird systemischer.

Resilienzstrategien:

- Staging / Canary Deployment / Rollback-Fähigkeit
- Separation of Duties / Vier-Augen-Prinzip
- Post-Mortem-Kultur statt Schuldpersonensuche

Prinzipbezug: Wiederherstellbarkeit + Governance (vgl. BSI-200-4 Reifegradstufen „gelernt vs. dokumentiert“)

> Ergänzung zur Vorlesung: AWS S3 2017
>
> Am 28. Februar 2017 wollte ein autorisierter Techniker bei AWS per Befehl wenige Server eines S3-Teilsystems entfernen. Eine Eingabe war falsch, und es fielen deutlich mehr Server weg. Zwei Kernsubsysteme mussten vollständig neu gestartet werden; S3 in der Region us-east-1 war von 9:37 bis 13:54 Uhr (Pacific Time) gestört, abhängige Dienste mit. Auch das Status-Dashboard hing an S3 und konnte lange nicht aktualisiert werden.
>
> AWS reagierte nicht mit Schuldzuweisung, sondern mit **Leitplanken im Werkzeug**: Kapazität wird nun langsamer und nie unter eine Mindestgrenze entfernt, weitere Werkzeuge wurden geprüft, das Index-Subsystem wird in kleinere Zellen aufgeteilt, und die Status-Konsole läuft in mehreren Regionen.
>
> Quellenangaben unter Quellen.

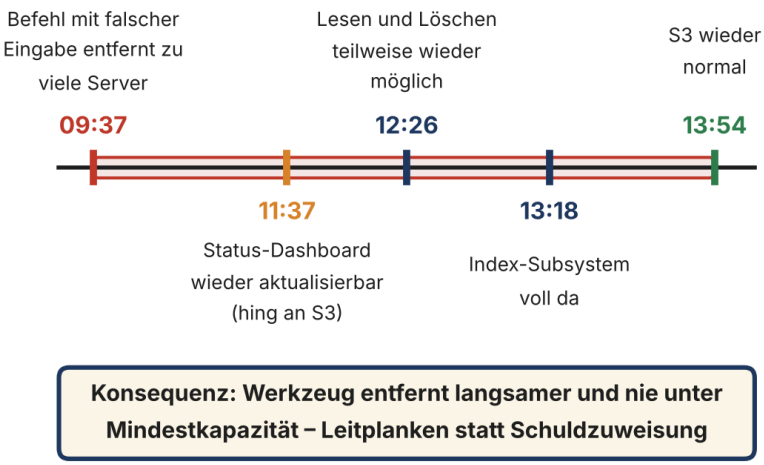


Abbildung 7: AWS S3 2017: Zeitleiste der Störung (Pacific Time)

4.6 Supply-Chain-Angriffe

Wirkmechanismus:

Externe Kompromittierung wird „mitimportiert" in die eigene Kontrollkette (SolarWinds-Typus).

Resilienzstrategien:

- Diversität in kritischen Dependencies (nicht Monokultur)
- Zero-Trust for Dependencies (keine implizite Vertrauensweitergabe)
- Recovery ohne Abhängigkeit vom kompromittierten Supplier-State

Prinzipbezug: Diversität + Isolation (vgl. ENISA Supply-Chain Risk Guidance)

Ergänzung zur Vorlesung: Count+Care und die Mainzer Stadtwerke 2022

Im Juni 2022 traf ein Ransomware-Angriff den IT-Dienstleister Count+Care, eine Tochter des Darmstädter Versorgers Entega. Mitbetroffen waren weitere Kunden, darunter die Mainzer Stadtwerke einschließlich Nahverkehr, die Frankfurter FES, die Darmstädter HEAG und Kommunen in Südhessen. Websites waren nicht erreichbar, tausende Beschäftigte kamen nicht an ihre E-Mail-Konten, im Nahverkehr kam es zu Ausfällen und eingeschränktem Ticketverkauf. Strom, Gas und Wasser liefen nach Angaben der Unternehmen weiter. Im Juli 2022 bestätigte Entega, dass die Täter personenbezogene Daten von Kunden, Beschäftigten und Geschäftspartnern veröffentlicht hatten.

Der Angriff traf einen Dienstleister – ausgefallen sind viele Organisationen. Zugleich zeigt der Fall Graceful Degradation: Die Versorgung als Kernfunktion war von der Büro-IT getrennt und blieb in Betrieb.

Quellenangaben unter Quellen.

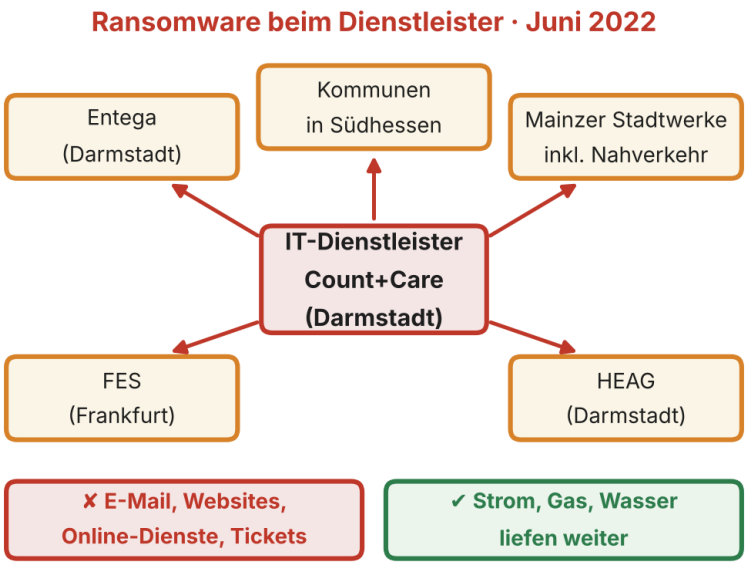


Abbildung 8: Count+Care 2022: ein Dienstleister, viele Betroffene

Ergänzung zur Vorlesung: Notkommunikation

Wer die eigene IT verliert, verliert meist auch die eigenen Kommunikationskanäle: E-Mail, Website, Intranet. Die Fälle dieser Sitzung zeigen Ersatzwege: Die Mainzer Stadtwerke richteten 2022 innerhalb weniger Tage eine neue Website unter einer Ersatzdomain und neue Kontaktadressen ein; die Hochschule Mainz informierte 2025 über ihre App und soziale Medien; AWS meldete 2017 den Status über Twitter, weil das Dashboard selbst betroffen war.

Notkommunikation ist damit eine Resilienzfähigkeit im Sinne von Redundanz und Diversität. Sie muss vorbereitet sein – außerhalb der eigenen IT und mit Absendern, die die Empfänger kennen, denn Angreifer nutzen Ausfälle gern für gefälschte Nachrichten.

Quellenangaben unter Quellen.

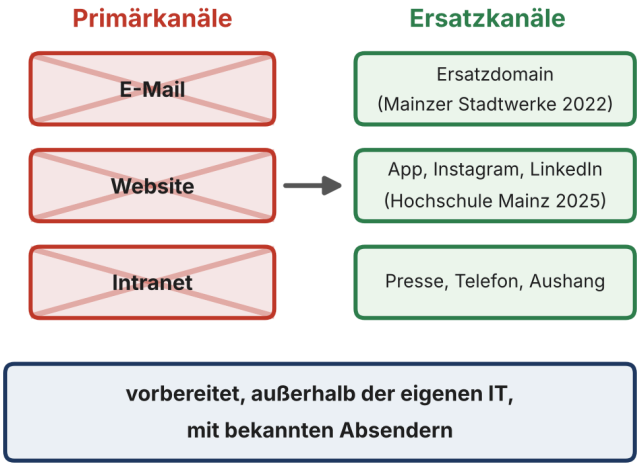


Abbildung 9: Primär- und Ersatzkanäle der Kommunikation

5. Normative Verankerung: Wie Frameworks Bedrohung → Resilienz koppeln

Resilienzmaßnahmen sind nicht frei interpretierbar, sondern in etablierten Normen als **fähigkeitsbezogene Reaktionen auf Bedrohungsszenarien** beschrieben. Damit ist Resilienz nicht nur ein Architekturthema, sondern ein **prüf- und nachweisfähiges Steuerungsprinzip**.

5.1 NIST SP 800-160 Vol. 2 – Capability-based Resilience

NIST formuliert Resilienz als Menge von Fähigkeiten (*capabilities*), die **explizit an Störereignisse gebunden** sind.

Die Kernkategorien — *Resist, Detect, Respond, Recover, Adapt* — wirken nicht unabhängig, sondern entlang beobachtbarer Bedrohungsfolgen. Resilienz wird damit **nicht an der Ursache, sondern am Effekt** ausgerichtet.

> ℹ Hinweis zur Aktualität
>
> NIST SP 800-160 Vol. 2 Rev. 1 (2021) definiert Cyber-Resilienz über die Ziele *Anticipate, Withstand, Recover, Adapt* [1]. Die hier verwendeten Begriffe (resist, re-constitute u. a.) stammen aus älteren Fassungen bzw. der Terminologie der Lehrveranstaltung. Siehe Quellen, Hinweis 1.

5.2 ISO/IEC 27031 – ICT Readiness for Business Continuity

ISO/IEC 27031 versteht Resilienz als Nachweisfähigkeit über:

- definierte Ziele (RTO/RPO),
- getestete Recovery-Fähigkeit,
- wiederkehrende Validierung (Exercises & Lessons Learned).

Der Standard fordert damit Resilienz **gegen konkrete Ausfallszenarien** — nicht nur vorbereitende Dokumentation.

5.3 BSI-Standard 200-4 – Reifegrad statt Checkliste

BSI-200-4 bewertet nicht, ob Maßnahmen existieren, sondern **wie wirksam sie im Ereignisfall** betrieben werden können.

Der Reifegrad bemisst sich **an der geübten Fähigkeit**, nicht an der formalen Existenz.

> ℹ Hinweis zur Aktualität
>
> Die finale Fassung des BSI-Standards 200-4 (Mai 2023) unterscheidet drei Stufen: Reaktiv-BCMS, Aufbau-BCMS und Standard-BCMS [2]. Die hier gezeigte fünfstufige Skala ist als allgemeines Reifegradmodell zu verstehen, nicht als Stufenmodell des Standards. Siehe Quellen, Hinweis 3.

5.4 ENISA – Sektorale Resilienz mit Threat-Fokus

ENISA-Guidelines adressieren Resilienz immer **sektorspezifisch** (z. B. Energie, Gesundheit, Finanzmarkt), da Bedrohungsmodelle sektoral divergieren. Resilienz wird dort nicht generisch, sondern **bedrohungsnah** formuliert.

Quintessenz: Normen bewerten Resilienz nicht als abstrakte Eigenschaft, sondern als **funktionale Antwortfähigkeit auf definierte Störungstypen**.

Damit sind Threat-to-Resilience-Mappings nicht optional, sondern methodisch gefordert.

6. Übung: Threat-to-Resilience-Mapping (Gruppenarbeit)

Die Übung dient der Überführung des Threat-Driven-Denkens in ein strukturiertes Analyse- und Argumentationsschema. Sie ist nicht als kreative Brainstorming-Aufgabe konzipiert, sondern als **präzise Zuordnungsaufgabe** entlang der in dieser Sitzung vermittelten Logik.

Aufgabenstellung Wählen Sie in Gruppenarbeit **eine der folgenden Bedrohungen**:

- Ransomware
- DDoS / Lastangriff
- Cloud-/Region-Ausfall
- Identity-Ausfall (IdP)
- Human Failure / Fehlkonfiguration
- Supply-Chain-Angriff

Beantworten Sie strukturiert:

1. **Wirkmechanismus**

   Wie genau führt die Bedrohung zur Funktionsbeeinträchtigung? (1–2 Sätze)

2. **Zuordnung zu Resilienzprinciples**

   Welches der vier Prinzipien (Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität) ist vorrangig relevant – und warum?

3. **Konkrete Resilienzmaßnahmen**

   Nennen Sie je Prinzip mindestens eine technisch realistische Maßnahme.

4. **Kurzfazit**

   Ist das System nach Umsetzung der Maßnahmen *resilient*, *bedingt resilient* oder weiterhin *fragil*? Begründen Sie in einem Satz.

Form des Ergebnisses

- 1 Slide oder 1 Blatt mit maximal 6 Bulletpoints

- Präsentationszeit pro Gruppe: 2–3 Minuten
- Bewertungskriterium: **Schärfe der Zuordnung, nicht Menge der Maßnahmen**

Weiter mit dem abschließenden Kapitel.

7. Zusammenfassung & Prüfungsrelevanz

Die Sitzung hat gezeigt, dass Resilienz nicht von der Bedrohung entkoppelt verstanden werden kann. Sie ist nicht „allgemein vorhanden“ oder „absolut“, sondern immer eine **Antwort auf einen konkreten Störmechanismus**. Bedrohungen unterscheiden sich weniger durch ihre Ursache als durch deren Auswirkung auf Funktionsfähigkeit, Steuerbarkeit und Wiederanlauf.

Kernpunkte dieser Sitzung

- Resilienz ist **relational** — sie existiert nur im Bezug zu einem Störungsszenario.
- Bedrohungsklassen (Ransomware, DDoS, Cloud-Failure, Identity, Human Error, Supply Chain) erzeugen **unterschiedliche Anforderungen**.
- Die vier Resilienzprinzipien (Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität) wirken als **strukturierter Antwortraum**.
- Normen (NIST SP 800-160 Vol.2, ISO/IEC 27031, BSI-200-4, ENISA) verankern dieses Mapping methodisch, nicht optional.
- Resilienzbewertung ohne Threat-Bezug ist **konzeptionell unvollständig**.

Prüfungsrelevante Leitfragen

- Warum ist Resilienz ohne Threat-Bezug methodisch unzureichend?
- Welche Bedrohung adressiert primär das Prinzip Wiederherstellbarkeit und warum?
- Wie unterscheidet sich das Wirkmodell eines DDoS von dem einer Ransomware — und wie spiegelt sich das im Resilienzdesign?
- Wie begründet BSI-200-4, warum Tests wichtiger sind als Dokumente?
- Erklären Sie an einem Beispiel, warum Identity ein versteckter SPOF ist.

Bibliografie

[1] R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, und R. McQuaid, „Developing Cyber-Resilient Systems: A Systems Security Engineering Approach“, NIST Special Publication 800-160 Vol. 2 Rev. 1, Dez. 2021. doi: 10.6028/NIST.SP.800-160v2r1.

[2] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.